ThreatSimGPT Audit Framework

Version: 1.0 **Effective Date:** January 20, 2026 **Last Updated:** January 20, 2026 **Document Owner:** Compliance Team (Jerry - okino007) **Review Cycle:** Annual

---

Executive Summary

This document establishes the comprehensive audit framework for ThreatSimGPT, providing governance, procedures, and technical controls for audit trail management, compliance reporting, and evidence collection.

Framework Status: IMPLEMENTED

Audit Framework Documentation Index

Document	Purpose	Status
Audit Logging Policy	Logging standards and requirements	Complete
Audit Events Catalog	Comprehensive event definitions	Complete
Compliance Reporting	Report generation and distribution	Complete
Evidence Collection	Procedures for audit evidence	Complete
Log Retention Policy	Retention schedules and archival	Complete
Audit Trail Integrity	Tamper-evident logging controls	Complete

---

Table of Contents

1. Framework Overview
2. Governance Structure
3. Audit Objectives
4. Scope and Applicability
5. Roles and Responsibilities
6. Compliance Requirements
7. Technical Architecture
8. Implementation Guidelines
9. Review and Maintenance
10. Contact Information

---

1. Framework Overview

Section 1.1 Purpose

The ThreatSimGPT Audit Framework provides:

Capability	Description
Accountability	Track all system activities to responsible parties
Compliance	Meet regulatory requirements (GDPR, HIPAA, SOC 2, PCI-DSS)
Forensics	Enable incident investigation and root cause analysis

Monitoring	Real-time detection of policy violations
Reporting	Generate compliance and operational reports

Section 1.2 Framework Principles

Principle	Implementation
Completeness	All security-relevant events logged
Integrity	Tamper-evident logging with checksums
Availability	Logs accessible for authorized queries
Confidentiality	Log data protected from unauthorized access
Retention	Logs retained per regulatory requirements
Non-repudiation	Events attributable to specific actors

Section 1.3 Standards Alignment

Standard	Relevant Controls
ISO 27001	A.12.4 (Logging and Monitoring)
SOC 2	CC7.2, CC7.3 (System Monitoring)
GDPR	Article 30 (Records of Processing)
HIPAA	164.312(b) (Audit Controls)
PCI-DSS	Requirement 10 (Track and Monitor Access)
NIST CSF	DE.CM (Security Continuous Monitoring)

---

2. Governance Structure

Section 2.1 Audit Committee

Role	Responsibility	Member
Audit Lead	Framework ownership, policy approval	Compliance Team
Technical Lead	Implementation oversight	Engineering Team
Security Lead	Threat monitoring, incident response	Security Team
DPO	Privacy compliance validation	Data Protection Officer

Section 2.2 Decision Authority Matrix

Decision	Authority Level	Approval Required
Policy changes	Audit Committee	Unanimous

Retention period changes	Audit Lead + DPO	Dual approval
Log access grants	Security Lead	Single approval
Emergency log access	Technical Lead	Post-hoc review
Audit report distribution	Audit Lead	Single approval

Section 2.3 Meeting Schedule

Meeting Type	Frequency	Participants
Audit Review	Monthly	Full committee
Incident Review	As needed	Relevant members
Policy Review	Quarterly	Full committee
Annual Assessment	Yearly	Full committee + stakeholders

---

3. Audit Objectives

Section 3.1 Primary Objectives

Objective	Success Criteria	Measurement
Compliance	Zero regulatory findings	Audit results
Detection	Less than 1 hour mean time to detect	SIEM metrics
Coverage	100% of critical events logged	Coverage reports
Integrity	Zero tamper incidents	Integrity checks
Availability	99.9% log query availability	SLA metrics

Section 3.2 Secondary Objectives

Objective	Description
Operational insights	Identify usage patterns and optimization opportunities
Capacity planning	Forecast resource requirements from usage trends
User behavior analytics	Detect anomalous patterns indicating compromise
Performance monitoring	Track system performance metrics

---

4. Scope and Applicability

Section 4.1 In-Scope Systems

System	Log Types	Priority
API Gateway	Access logs, rate limiting	Critical

Authentication Service	Login/logout, MFA events	Critical
Simulation Engine	Execution logs, outputs	Critical
Database	Query logs, schema changes	High
File Storage	Access logs, modifications	High
Admin Console	Configuration changes	Critical
Background Jobs	Batch processing logs	Medium

Section 4.2 Event Categories

Category	Examples	Retention
Authentication	Login, logout, MFA, password changes	1 year
Authorization	Access grants, denials, privilege changes	1 year
Data Access	Read, write, delete operations	90 days
Configuration	System settings, policy changes	2 years
Security	Alerts, incidents, vulnerability scans	2 years
Compliance	DSAR requests, consent changes	3 years
Operational	Performance metrics, errors	30 days

Section 4.3 Out of Scope

Item	Reason
Debug logs	High volume, low security relevance
Anonymized analytics	No personal data
Third-party system internals	Managed by vendors

---

5. Roles and Responsibilities

Section 5.1 RACI Matrix

Activity	Audit Lead	Tech Lead	Security	DPO	Engineering
Policy definition	A	C	C	C	I
Log implementation	I	A	C	I	R
Log monitoring	I	I	A	I	R
Incident investigation	C	C	A	C	R
Compliance reporting	A	C	C	R	I

Evidence collection	A	R	R	C	R
Access management	C	R	A	C	I

Legend: R=Responsible, A=Accountable, C=Consulted, I=Informed

Section 5.2 Role Definitions

Role	Responsibilities
Log Producer	Implement logging in application code
Log Consumer	Query and analyze logs for insights
Log Administrator	Manage log infrastructure and retention
Auditor	Review logs for compliance validation
Incident Responder	Investigate security events

---

6. Compliance Requirements

Section 6.1 Regulatory Mapping

Regulation	Requirement	Implementation
GDPR Art. 30	Records of processing	Audit events catalog
GDPR Art. 33	Breach notification	Incident logging
HIPAA 164.312(b)	Audit controls	Comprehensive logging
SOC 2 CC7.2	System monitoring	Real-time alerting
PCI-DSS 10.1	Audit trails	User action logging
PCI-DSS 10.2	Event logging	Authentication events
PCI-DSS 10.3	Log entries	Structured log format
PCI-DSS 10.5	Log integrity	Tamper-evident storage
PCI-DSS 10.7	Log retention	Retention policy

Section 6.2 Compliance Controls

Control ID	Control	Evidence
AUD-001	All authentication events logged	Auth log samples
AUD-002	All authorization decisions logged	Access log samples
AUD-003	All data modifications logged	Data change logs
AUD-004	Logs protected from modification	Integrity reports
AUD-005	Logs retained per policy	Retention verification

AUD-006	Log access restricted	Access control reports
AUD-007	Regular log review performed	Review records
AUD-008	Alerts configured for anomalies	Alert configuration

---

7. Technical Architecture

Section 7.1 Logging Infrastructure

```
+-----------------+     +-----------------+     +-----------------+
|  Application    |     |  Log Shipper    |     |  Log Storage    |
|  Components     |---->|  (Fluent Bit)   |---->|  (OpenSearch)   |
+-----------------+     +-----------------+     +-----------------+
        |                       |                       |
        v                       v                       v
+-----------------+     +-----------------+     +-----------------+
|  Structured     |     |  Enrichment     |     |  Indexing       |
|  Log Format     |     |  Pipeline       |     |  and Search     |
+-----------------+     +-----------------+     +-----------------+
                                                        |
                                                        v
                                                +-----------------+
                                                |  Dashboards     |
                                                |  and Alerts     |
                                                +-----------------+
```

Section 7.2 Log Format Standard

All logs follow the Common Event Format (CEF) extended schema:

```
{
  "timestamp": "2026-01-20T12:00:00.000Z",
  "event_id": "evt_abc123def456",
  "event_type": "authentication.login.success",
  "severity": "INFO",
  "actor": {
    "user_id": "usr_123",
    "username": "john.doe",
    "ip_address": "192.168.1.100",
    "user_agent": "Mozilla/5.0..."
  },
  "target": {
    "resource_type": "session",
    "resource_id": "sess_789"
  },
  "context": {
    "session_id": "sess_789",
    "request_id": "req_456",
    "correlation_id": "corr_123"
  },
  "outcome": {
```

```
    "status": "success",
    "reason": null
  },
  "metadata": {
    "service": "auth-service",
    "version": "1.0.0",
    "environment": "production"
  },
  "checksum": "sha256:abc123..."
}
```

Section 7.3 Integrity Controls

Control	Implementation
Event signing	SHA-256 checksum per event
Chain integrity	Previous event hash linkage
Immutable storage	Write-once storage backend
Access logging	All log queries logged
Backup verification	Daily integrity checks

---

8. Implementation Guidelines

Section 8.1 Developer Requirements

Requirement	Description
Use AuditLogger	All audit events through central logger
Include context	Session, request, correlation IDs
Structured format	JSON with required fields
Appropriate severity	Match event to severity level
No sensitive data	Mask PII, credentials, tokens

Section 8.2 Code Example

```
from threatsimgpt.audit import AuditLogger, AuditEvent, Severity

audit = AuditLogger()

# Log authentication event
await audit.log(AuditEvent(
    event_type="authentication.login.success",
    severity=Severity.INFO,
    actor_id=user.id,
    actor_ip=request.client.host,
    target_type="session",
```

```
    target_id=session.id,
    outcome="success",
    context={
        "mfa_used": True,
        "auth_method": "password"
    }
))
```

Section 8.3 Severity Levels

Level	Value	Usage
EMERGENCY	0	System unusable
ALERT	1	Immediate action required
CRITICAL	2	Critical conditions
ERROR	3	Error conditions
WARNING	4	Warning conditions
NOTICE	5	Normal but significant
INFO	6	Informational
DEBUG	7	Debug-level (not in production)

---

9. Review and Maintenance

Section 9.1 Review Schedule

Review Type	Frequency	Owner
Log coverage audit	Monthly	Technical Lead
Policy compliance	Quarterly	Audit Lead
Retention verification	Monthly	Log Administrator
Access review	Quarterly	Security Lead
Framework assessment	Annual	Audit Committee

Section 9.2 Change Management

Change Type	Process
New event types	Technical review + documentation update
Retention changes	Committee approval + regulatory review
Access changes	Security approval + documentation
Infrastructure changes	Change advisory board approval

Section 9.3 Metrics and KPIs

Metric	Target	Measurement
Log ingestion latency	Less than 5 seconds	P95 latency
Query response time	Less than 2 seconds	P95 latency
Log coverage	100% critical events	Coverage reports
False positive rate	Less than 5%	Alert analysis
Retention compliance	100%	Retention audits

---

10. Contact Information

Contact	Email	Responsibility
Audit Lead	audit@threatsimgpt.io	Policy questions
Security Team	security@threatsimgpt.io	Incident response
Compliance	compliance@threatsimgpt.io	Regulatory questions
DPO	dpo@threatsimgpt.io	Privacy concerns

Document Control

Version	Date	Author	Changes
1.0	2026-01-20	Jerry (okino007)	Initial release

This framework is maintained by the ThreatSimGPT Compliance Team. Next review: January 20, 2027